

BUG: Memory leak in function `Py_Find0bjects` due to new reference is not decreased (static analyzer report) #16235

Closed

#16397

Snape3058 opened on May 21, 2022

1. A new reference is returned and assigned to `tuple`.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 888 in 8627df3

```
888     PyObject *tuple = PyTuple_New(PyArray_NDIM(input));
```

2. Assume `tuple` is not NULL.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 889 in 8627df3

```
889     if (!tuple) {
```

3. Assume taking the true branch.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 897 in 8627df3

```
897     if (!start || !end) {
```

4. Goto `exit`. `tuple` goes out-of-scope without decreasing the refcnt.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 899 in 8627df3

```
899     goto exit;
```

Internal Report ID: c5db6d

NOTE: the local variable `tuple` declared here is never used apart from line 925.

[scipy/scipy/ndimage/src/nd_image.c](#)

Line 850 in 8627df3

```
850     PyObject *result = NULL, *tuple = NULL, *start = NULL, *end = NULL;
```

 **rgommers** added **defect** on Jun 14, 2022

 **rgommers** added a commit that references this issue on Jun 14, 2022

BUG: fix a minor refcounting issue in `Py\_FindObjects` ...

 9b65211

 **rgommers** mentioned this on Jun 14, 2022

 MAINT: fix two refcounting issues in `ndimage` #16397

 rgommers on Jun 14, 2022

Member ...

Thanks for the clear report [@Snape3058](#). [gh-16397](#) contains a fix.

 **tylerjereddy** added **scipy.ndimage** on Jun 14, 2022

 **tylerjereddy** closed this as completed in [#16397](#) on Jun 14, 2022

 **tylerjereddy** added this to the 1.10.0 milestone on Jun 14, 2022

 rgommers on Jul 7, 2023

Member ...

This just got assigned a CVE: <https://nvd.nist.gov/vuln/detail/CVE-2023-25399>. There's a couple of problems with that:

1. It wasn't disclosed in private to us - as is best practice, and we have a way of doing it advertised in our README
2. It does not seem like a valid CVE:
 - The only way to trigger that memory leak is when calling `ndimage.find_objects`, at which point the caller already can execute arbitrary Python code - and then there are far more impactful things they can do than cause a small memory leak.
 - This open issue tracks other reported and potential refcounting errors:  [Potential refcounting errors reported by pytest-leaks #11142](#). In general, those are technically bugs but not security issues.
 - SciPy is *not* designed to be exposed to untrusted users or untrusted data directly. This is the case for any numerical Python package and the CPython interpreter itself - unless advertised otherwise. See the guidance in <https://www.python.org/dev/security/> and <https://numpy.org/devdocs/reference/security.html> for example.

[@Snape3058](#) did you apply for this CVE? If so, could you please not do that for any other issues before discussing with us in private first? CVEs, even if later deemed invalid, cause a large amount of work for us and for many of our users.

3

 Snape3058 on Jul 7, 2023

Author ...

Sorry for the inconvenience that our team brought to this project.
I did not do this myself, but my mentor asked other teammates to apply for some CVE IDs for my confirmed bug reports.
I will forward your reply and let them know about the rules.
Apologize again for this.
My teammates will then get in contact with you and discuss this one.

rgommers on Jul 7, 2023

Member ...

Thank you [@Snape3058](#), much appreciated.

nonsense-j on Jul 8, 2023

...

I apologize for the inconvenience caused by my personal negligence in applying this CVE. I misassessed the harmfulness of this vulnerability, and the problems you mentioned do exist. Here are some expected solutions to your problems:

1. For this issue, I will update this cve by rejecting assignment.
2. I wonder how I can disclose vulnerabilities in private to you. There is another issue I requested for cve at the same time though I labeled that it has been fixed.
Really sorry again for causing that much work for you.



wnhsu added a commit that references this issue [on Jul 10, 2023](#)

update scipy version due to security vulnerability ...

258fb50

rgommers on Jul 10, 2023

Member ...

Thank you [@nonsense-j](#), that sounds good!

I wonder how I can disclose vulnerabilities in private to you

As noted above, we have a link in our main README (which points to <https://tidelift.com/docs/security>). That said, now that we're already talking, it's easier to send me a private email directly - ralf.gommers@gmail.com



rgommers mentioned this [on Jul 11, 2023](#)

🔍 [BUG: Potential use-after-free bug in function Py_FindObjects](#) [#14713](#)



SH2282000 mentioned this [on Jul 18, 2023](#)

🔍 [Scipy dependency present the CVE-2023-25399 treeverse/dvclive#629](#)



ElijahKagan added a commit that references this issue [on Jul 19, 2023](#)

Update scipy ...

49b7017



ElijahKagan mentioned this [on Jul 19, 2023](#)

[Update scipy dmvassallo/EmbeddingScratchwork#213](#)

  **EliahKagan** added a commit that references this issue [on Jul 19, 2023](#)

Update scipy ([#213](#)) 

Verified fc061c9

  **dschwoerer** mentioned this [on Jul 19, 2023](#)

[Bump scipy and remove requirements.txt boutproject/boututils#51](#)

  **qraa** mentioned this [on Jul 25, 2023](#)

[Fix PYSEC-2023-102 vulnerability QuTech-Delft/netqasm#57](#)

  **harupy** mentioned this [on Oct 3, 2023](#)

 [\[BUG\] Security Vulnerability CVE-2023-25399 mlflow/mlflow#9807](#)

  **rickprice** added 2 commits that reference this issue [on Oct 14, 2023](#)

[CVE-2023-25399](#) Cherry-pick [9b65211](#) 

 3266eb5

[CVE-2023-25399](#) Cherry-pick [9b65211](#) 

 d3d8a95

  **mhsmith** mentioned this [on Oct 17, 2025](#)

 [SciPy for Python 3.11 or later chaquo/chaquopy#1237](#)

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

defect scipy.ndimage

Type

No type

Projects

No projects

Milestone

 **1.10.0**

Closed on Jan 4, 2023, 100% complete

Relationships

None yet

Development

 Code with agent mode



 MAINT: fix two recounting issues in `ndimage`

scipy/scipy

Participants

